

SEC105 - Architectures et bonnes pratiques de la sécurité des réseaux, des systèmes, des données et des applications

Concepteur Architecte Informatique (toutes spécialités)

1

Objectif : Comprendre le fonctionnement et les vulnérabilités, configurer, exploiter, superviser les exigences de sécurité de base pour accéder aux réseaux d'entreprise et protéger les accès aux actifs essentiels et support de l'entreprise :

Thème : Contrôle d'accès et sécurité de l'information

Le contrôle d'accès

Définition historique:

La sécurité des systèmes d'information comprend trois étapes essentielles :

- la prévention,
- la protection,
- la détection

Le contrôle d'accès est un composant central car il est directement responsable des actions accordées ou refusées à l'utilisateur, et donc de la manipulation des données présentes dans le système d'information.

Par conséquent, les mécanismes de contrôle d'accès doivent non seulement être capables d'autoriser les actions légitimes, mais aussi de refuser, voir bloquer, les actions considérées comme illégitimes.

Le contrôle d'accès

Terminologie

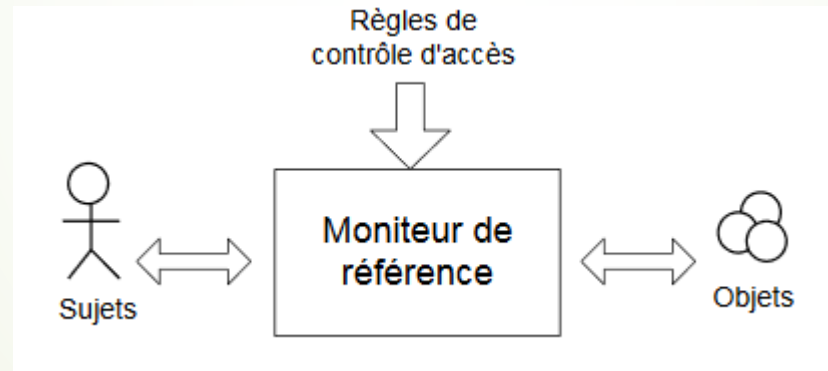
- Système d'information :
 - Ensemble des utilisateurs, machines, et logiciels amenés à interagir.
- Contrôle d'accès :
 - Ensemble de règles régissant les permissions des utilisateurs sur les machines et logiciels
- Les règles :
 - Lois d'accès de la part des sujets (entités actives du système) sur les objets (entités passives)

Chacun de ces accès est contrôlé par le Moniteur de Références [Anderson 1972] responsable de l'application de la politique de sécurité.

Le contrôle d'accès

Moniteur de Référence

C'est la représentation conceptuelle de l'ensemble des mécanismes qui mettent en œuvre les règles définies par la politique de contrôle d'accès.



Le contrôle d'accès

Modèles de contrôle d'accès

- La caractéristique commune à tous ces modèles de contrôles d'accès est qu'ils considèrent trois ensembles
 - l'ensemble des sujets S qui représentent les entités qui exécutent des requêtes sur les objets (par exemple les utilisateurs, les processus). Ces entités sont dites actives
 - l'ensemble des objets O qui représentent les entités qui reçoivent ou contiennent de l'information (par exemple les fichiers). Ces entités sont dites passives.
 - l'ensemble des droits d'accès R des sujets sur les objets.
- Une politique de contrôle d'accès consiste donc en un ensemble de relations sur $S \times O \times R$.
- Les différences qui existent entre ces modèles portent sur les droits d'accès, la façon de grouper les sujets/objets et donc les relations sujets-droits-objets.

Modèles d'accès

Premier modèle historique : le modèle discrétionnaire → DAC [Lampson 1971]

Modèle DAC (Discretionary Access Control) – Notez que c'est le premier modèle appliqué à tous les systèmes multi-utilisateurs.

- Ce modèle considère que chaque sujet (utilisateur) peut détenir un droit de possession sur un objet
- Ce droit particulier lui permet d'ajouter ou de soustraire des droits d'accès pour lui ou pour les autres
 - Souvent attribué au créateur de l'objet.
- Il existe un super-utilisateur sur le système qui a tout pouvoir sur le système.

La sécurité de ce modèle a longtemps semblé satisfaisante, tant que l'accès super-utilisateur était contrôlable.

Depuis, les erreurs de programmation, les vulnérabilités applicatives ainsi que le développement des techniques d'exploitation des failles induit de nouveaux moyens d'accéder aux privilèges du super-utilisateur, et ainsi d'outrepasser le DAC.

Modèles d'accès

Premier modèle historique : le modèle discrétionnaire

OUTIL : Matrice de contrôle d'accès :

- Introduit par Lampson [Lampson 1971] puis améliorée par Graham et Denning [Denning 1971, Graham et al. 1972]
- Une matrice de contrôle d'accès est une fonction $A : S \times O \rightarrow R$ qui donne pour chaque couple (sujet, objet), l'ensemble des droits associés.
- Tout sujet peut avoir le droit de possession
- L'analyse s'effectue sur des états appelés états de protection qui sont représentés par des triplets (S, O, A) où S est l'ensemble des sujets, O l'ensemble des objet et A la matrice de contrôle d'accès

		Objets				
		Fichier 1	Segment 1	Segment 2	Processus 2	Editeur
Sujets						
Processus	1	Lire	Executer	Lire Ecrire		Entrer
Processus	2	Lire Ecrire				Entrer
Processus	3		Lire Ecrire Executer		Entrer	Entrer

Modèles d'accès

Premier modèle historique : le modèle discrétionnaire

OUTIL : Matrice de contrôle d'accès → PROBLEME

- Le sujet S1 crée le fichier toto.txt.
- Il en devient propriétaire.
- Il décide de donner le droit de lecture au sujet S2 mais pas au sujet S3. Cette règle constitue sa politique de contrôle d'accès.
- Lorsque S2 lit le fichier toto.txt, il décide de recopier le contenu dans un nouveau fichier copie_toto.txt
- Maintenant, S2 détient les droits de possession sur le fichier copie_toto.txt qui contient la même information de toto.txt.
- Il décide d'en donner le droit de lecture à s3.

S3 peut lire l'information contenue dans copie_toto.txt et donc toto.txt

Modèles d'accès

le modèle discrétionnaire : Evolutions → modèle HRU [Harrison & al. 1976]

HRU : Amélioration du modèle de Lampson pour la vérification des droits.

- ▶ HRU utilise une matrice de contrôle d'accès classique, la différence réside en ce que HRU précise les commandes qui peuvent lui être appliquées.

Entrer a dans $A[s,o]$	Supprimer a de $A[s,o]$
Créer le sujet s	Détruire le sujet s
Créer l'objet o	Détruire l'objet o

Modèles d'accès

le modèle discrétionnaire : Evolutions → modèle HRU [Harrison & al. 1976]

HRU : Amélioration du modèle de Lampson pour la vérification des droits.

- A partir de ces opérations élémentaires, il est possible de créer des commandes.

- Exemple :

Commande délivrer_lecture ($S1, S2, F$)

si lire $\in A[S1, S2]$ **et** copie $\in A[S1, F]$

alors

entrer lire dans $A[S2, F]$

fin

Avec $S1$ et $S2$ les sujets, F le fichier et A l'accès

Modèles d'accès

le modèle discrétionnaire : Evolutions → modèle HRU [Harrison & al. 1976]

HRU : Amélioration du modèle de Lampson pour la vérification des droits.

- Se pose la question de déterminer si un tel système est sécurisé ?
- La question étant : *Existe-t'il une séquence d'opération qui amène un droit d'accès a à se retrouver dans une case de la matrice d'accès ou il ne devrait pas être ?*
- La question a été démontrée par trois théorèmes concernant la complexité du problème. La question est indécidable dans le cas général.

Modèles d'accès

Vers une évolution du modèle

- Les modèles de politiques discrétionnaires ont une approche complètement distribuée des droits d'administration (droit de possession, take, grant, etc.).
- Cette approche pose le problème de protection qui peut se résumer à : est ce qu'un droit spécifique ne va pas être détenu par la mauvaise personne ?
- Une autre famille de modèles formels, dits d'autorisation obligatoire, règle ce problème en centralisant l'autorité d'administration
 - Les droits de type possession ou grant n'y existent pas.

Modèles d'accès

Mandatory access control (MAC) ou modèle obligatoire :

Le modèle Bell LaPadula [Bell et al.1973] :

- Modèle militaire permettant de définir des politiques garantissant la propriété de confidentialité, i.e. qui prévient la divulgation non autorisée d'information.
- Les permissions d'accès sont définies à travers une matrice de contrôle d'accès et un ensemble de niveaux de sécurité.
- Etant donné qu'il n'est pas possible d'ajouter/supprimer des droits comme dans les politiques DAC, les politiques de type Bell-LaPadula considèrent les flux d'informations qui se produisent quand un sujet observe ou modifie un objet et non l'état de protection du système.

Modèles d'accès

Mandatory access control (MAC) ou modèle obligatoire :

Le modèle Bell LaPadula [Bell et al.1973] :

- Il s'appuie sur l'association de différents niveaux de confidentialité aux sujets (appelés dans ce cas niveaux d'habilitation) et aux objets (appelés dans ce cas niveaux de classification)
 - Pour un objet o , sa classification $fo(o)$ est un moyen de représenter le danger que peut constituer la divulgation de l'information contenue dans cet objet.
 - Pour un sujet s , c'est une habilitation $fs(s)$ qui désigne la confiance qui lui est accordée.
- Chaque niveau $n = (cl, C)$ est caractérisé par ses deux attributs:
 - cl : une classification prise dans un ensemble totalement ordonné, par exemple : {non-classifié<confidentiel<secret}
 - C : un compartiment défini par un ensemble de catégories i.e. il décrit le type d'information, par exemple {nucléaire, défense}.

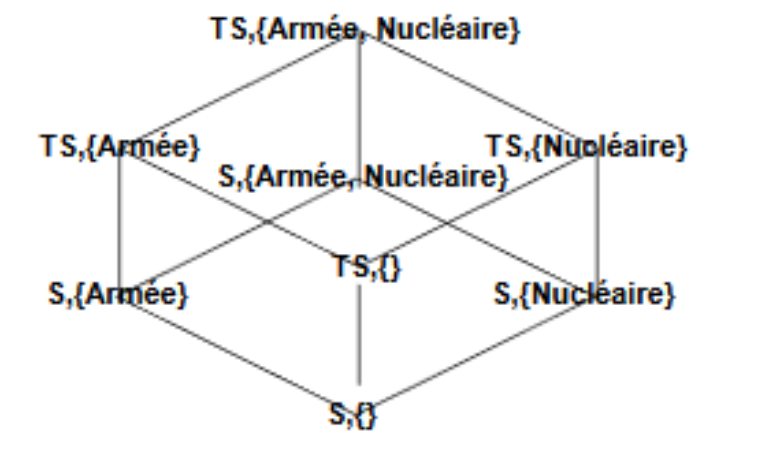
Modèles d'accès

Mandatory access control (MAC) ou modèle obligatoire :

Le modèle Bell LaPadula [Bell et al.1973] :

- Les niveaux constituent un treillis par une relation de dominance notée " $\leq$ " et définie par : Soit $n = (cl, C)$, $n' = (cl', C')$,

Si $n \leq n' \Leftrightarrow cl \leq cl'$ alors C appartient à C' . On dit alors que n' domine n



Modèles d'accès

Mandatory access control (MAC) ou modèle obligatoire :

Quantité d'autres modèles ont évolués de celui-ci :

- BLP
- Biba [Biba 1977]
- Clark-Wilson [Clark et al. 1987]
- muraille de Chine [Brewer et al. 1989]

Tous ces modèles mettent en avant la fonction du sujet, plutôt que le sujet, et le niveau de criticité de l'objet plutôt que les droits sur l'objet en lui-même.

Modèles d'accès

Contrôle d'accès non-discretionnaire ou RBAC (Role Based Access Control)

- Le RBAC accorde l'accès en fonction du poste et non en fonction de l'identité de l'utilisateur.
- L'objectif est de fournir aux utilisateurs l'accès aux données considérées comme nécessaires pour remplir leurs fonctions au sein de l'entreprise.
- Cette méthode largement utilisée repose sur une combinaison complexe de tâches, d'autorisations et de permissions.

Modèles d'accès

Contrôle d'accès non-discretionnaire ou RBAC (Role Based Access Control)

- Constatation simple :
 - les permissions accordées aux sujets sont données par rapport aux fonctions qu'ils occupent dans l'organisation
- Définition d'un rôle :
 - Une **fonction** dans le **contexte d'une organisation** dont la **sémantique dépend de l'autorité et des responsabilités** des utilisateurs qui sont assignés à ce rôle
- Différence entre notions de rôle et de groupe :
 - Un rôle est une fonction dans une organisation. Un groupe est un ensemble d'entités. Par conséquent, l'ensemble des sujets assignés à un même rôle forme un groupe.
 - La réciproque n'est pas forcément vraie car un groupe peut être formé de plusieurs entités associées à des rôles différents.

Modèles d'accès

Le modèle RBAC [ANSI359]

- Possibilité de définir des contraintes permettant d'exprimer la séparation de certains pouvoirs à cause de conflits d'intérêt par exemple.
- RBAC propose deux types de séparation de fonctions :
 - les séparations de fonction statiques (Static Separation of Duties - SSD)
 - Empêcher l'assignation d'un utilisateur à deux rôles en conflit
 - Empêcher qu'une hiérarchie de rôles amène un utilisateur à posséder les permissions de deux rôles en conflit
 - les séparations de fonction dynamique (Dynamic Separation of Duties - DSD)
 - La DSD porte sur Session_Rôles et donc
 - Eviter qu'un utilisateur possède deux rôles en conflit dans une même session
 - Contrairement à la SSD, la DSD n'implique pas que l'utilisateur ne soit pas assigné à deux rôles. Elle empêche simplement que l'utilisateur bénéficie des permissions des deux rôles en même temps.

Modèles d'accès : implémentation

Dans la partie précédente nous avons abordé les modèles théoriques de contrôle d'accès.

Au-delà de la définition de ces modèles, il est essentiel de disposer d'implantations fiables de ceux-ci sur les systèmes d'exploitation courants pour pouvoir réaliser pleinement leurs objectifs.

Dans l'environnement Linux :

- *Le noyau Linux, au cœur des systèmes d'exploitations dits GNU/Linux, est relativement jeune comparé aux modèles théoriques que nous avons étudiés dans la section précédente.*
- *Toutefois, les implantations de modèles de contrôle d'accès type MAC et RBAC n'ont commencé que tard dans l'évolution de celui-ci.*
- *En effet, le développement de Linux a débuté en 1991, et les premières implantations de mécanismes avancés de contrôle d'accès (c'est-à-dire autres que le DAC déjà intégré au noyau) ne sont apparues que vers 1997.*

Modèles d'accès : implémentation

Les différentes implantations présentées par la suite sont :

- **Medusa DS9**

Premier à avoir implémenté une forme de MAC pour le noyau Linux, dès 1997

- **RSBAC**

Rule Set-Based Access Control : implantation de mécanismes de contrôle d'accès dans les systèmes d'ex-ploitation, qui à pour objectif de supporter la plupart des modèles de contrôle d'accès existants.

- **LIDS**

Linux Intrusion Detection System, lancé en 1999, avec comme objectif initial l'implantation d'un système de détection d'intrusion dans le noyau Linux.

- **SELINUX**

Commencé dans les année 2000, intégré au développement du noyau Linux, et à l'origine de Linux Security Modules. (détaillé après)

- **Grsecurity**

Il s'agit d'un système de contrôle d'accès obligatoire. Il est utilisé par exemple dans le cas où il est utile de restreindre l'accès à certaines ressources au seul utilisateur root.

Modèles d'accès : implémentation

SELinux :

- SELinux définit les contrôles d'accès pour les applications, processus et fichiers d'un système. Il utilise des politiques de sécurité, c'est-à-dire des ensembles de règles qui indiquent à SELinux ce à quoi un utilisateur peut accéder ou non, pour mettre en application les autorisations d'accès définies par une politique.
- Ainsi, lorsqu'un sujet (une application ou un processus) envoie une requête pour accéder à un objet (par exemple un fichier), SELinux consulte un cache AVC (Access Vector Cache) où sont temporairement stockées les autorisations d'accès pour les différents sujets et objets.
- Si SELinux n'est pas en mesure de prendre une décision relative à l'accès en se basant sur les autorisations stockées dans le cache AVC, il envoie une requête au serveur de sécurité.
- L'autorisation d'accès est ensuite accordée ou refusée.

Principe de moindre privilège

Dans le domaine militaire, il existe une expression connue qui résume très bien la définition du principe de moindre privilège : « le besoin d'en connaître ».

- Pour les militaires, cela signifie qu'une information sensible n'est confiée qu'à ceux qui ont besoin de cette information pour remplir leurs fonctions.
- L'idée est la même en cybersécurité.
- Il implique donc de restreindre les droits d'accès d'un utilisateur précis dans l'entreprise, afin qu'il n'ait accès qu'à ceux qui lui sont nécessaires pour effectuer son travail.
- Selon ce même principe, chaque processus, appareil et application du système doit se voir attribuer la moindre autorité nécessaire, pour éviter de compromettre des informations privilégiées.

Dans l'idée, il s'agit de donner des accès minimums à tout le monde afin de réduire la « surface d'attaque » et, par conséquent, de réduire les risques encourus par l'entreprise.

Principe de moindre privilège

- Le concept de Moindre privilège est un élément pratique dans la plupart des réglementations de cybersécurité, et évoque le besoin d'une "protection en profondeur »

Dans les faits, cela signifie porter l'accent sur la nécessité de contrôler les accès à privilèges.

- La PAM (Privileged Access Management ou gestion des accès à privilèges), qui permet d'appliquer le principe de moindre privilège, constitue un élément crucial du suivi de la conformité de cette norme.

Principe de moindre privilège

- Le point de départ de ce principe est un audit complet des privilèges su SI.
- Puis il faut définir et organiser la politique de privilège : définir quel privilège pour quel type de compte d'utilisateur ou de service (déterminer qui a effectivement besoin d'accéder à telles ressources, données et systèmes et qui n'en a pas besoin).
- Mise en place d'une organisation et de procédures claires (demande de privilèges, audit des privilèges etc.
- Réattribuer les privilèges.

Des outils permettant de centraliser tous les privilèges du SI en un seul emplacement peuvent également permettre de maintenir au mieux ce principe, et d'aider à limiter les erreurs.

Conclusion – Synthèse

Le contrôle d'accès est un composant central car il est directement responsable des actions accordées ou refusées à l'utilisateur, et donc de la manipulation des données présentes dans le système d'information.

L'ensemble des mécanismes qui mettent en œuvre les règles définies par la politique de contrôle d'accès est portée de manière conceptuelle par une entité désignée comme « moniteur de référence »

3 modèles émergent au fur et à mesure du temps et des besoins :

- *Le modèle discrétionnaire*
- *Le modèle obligatoire (MAC)*
- *Le modèle non-discretionnaire (RBAC)*

Ces 3 modèles sont des modèles théoriques de contrôle d'accès, qui doivent bien entendu être implantés sur des systèmes, via diverses implémentations.

Mais pour garantir une bonne gestion de ces privilèges, il est nécessaire de mettre en œuvre une stratégie et une politique générale de gestion des privilèges : dans cette optique, nous avons abordé le principe de moindre privilège.